



University of Piraeus
School of Information and Communication Technologies
Department of Digital Systems
MSc 'Cybersecurity and Artificial Intelligence Technologies'

Security and Privacy Legal Framework
Spyware Technologies

Supervising Professors: K. Lambrinoudakis – S. Gritzalis

Βιτιόν Αντριάννα	andriana_vition@ssl-unipi.gr
Ioannis Kalaitzidis	ioannis_kalaitzidis@ssl-unipi.gr
Σπίνουλα Ιωάννα	ioanna_spinoula@ssl-unipi.gr

Piraeus

Abstract

The rapid evolution of spyware from simple commercial surveillance tools (adware) to advanced weapons of digital warfare — targeting politicians, journalists, lawyers, and human rights activists — has exposed the structural inadequacy of a purely legal and reactive defence strategy.

In contrast to this technical failure, the assignment proposes a methodology of preventive (ex-ante) architectural design for privacy, based on the international standard ISO/IEC 29100:2024 and Privacy Enhancing Technologies (PETs).

Abstract

This master's project addresses the rapidly evolving threat of spyware, analyzing its transition from simple commercial tracking tools (adware) to highly sophisticated, state-sponsored cyberweapons like Pegasus and Predator. As the smartphone serves as the central hub of human activity, its targeted compromise is not merely a security incident; it constitutes a profound violation of fundamental rights and democratic processes, establishing a modern "Digital Panopticon".

The first segment investigates the technical infection mechanisms, placing special emphasis on zero-click exploits and social engineering attacks (spear-phishing). It also analyzes advanced anti-forensic techniques, such as memory-only execution and built-in self-destruct mechanisms, which render traditional digital forensics exceptionally difficult. Detecting these threats now requires specialized frameworks like the Mobile Verification Toolkit (MVT) and deep packet capture analysis to successfully identify indicators of compromise (IoCs).

Subsequently, the thesis highlights the structural gap between the legal framework and technological reality. Institutional documents like the GDPR frequently prove inadequate against state actors and international legislative uncertainty. Thus, the research underscores the imperative need for technological shielding through "Privacy by Design". The ISO/IEC 29100 international standard is championed as the foundational blueprint for redefining software engineering, shifting focus from perimeter infrastructure protection to rigorously securing Personally Identifiable Information (PII) at its core.

The practical component is built upon two extensive case studies demonstrating the need for Zero Trust architectures. The first (ex-post) study examines the FORCEDENTRY exploit (CVE-2021-30860) targeting Apple's iMessage. By exploiting an integer overflow in the JBIG2 decoder to simulate an Arithmetic Logic Unit (ALU) within the device's memory, attackers completely bypassed defenses like Sandboxing (BlastDoor) and Code Signing. This highlights the industry's necessary shift towards memory-safe programming languages, perfectly aligning with ISO 29100 principles.

The second case study (ex-ante design) focuses on developing a resilient Electronic Health Record (EHR) system. Assuming the physician's endpoint device might already be silently infected, the system is architecturally designed to prevent mass data exfiltration. Integrating the ISO/IEC 27701 standard, the design enforces strict Role-Based Access Control (RBAC) -benchmarked against Hong Kong's Cap. 625 legal framework -and implements advanced Privacy- Enhancing Technologies (PETs) like de-identification at the database level.

In conclusion, the thesis summarizes emerging challenges, including the "AI Paradox" and "Vibe Coding", which facilitate the automated generation of polymorphic spyware and lower the technical barrier to entry. The final takeaway establishes that privacy can no longer be treated as a reactive legal compliance checklist. Instead, it must be embedded as an architecturally non-negotiable component of the source code (e.g., via Trusted Execution Environments-TEEs) to ensure data protection in an ecosystem where initial compromise is now considered inevitable.

Contents

1. Introduction to digital espionage and threat evolution.....	
Definition of spyware and distinction from other malware.....	
1.2 Από τα adware στο state-sponsored spyware.....	8
Targets, motivations and the 'Digital Panopticon'.....	
The necessity for a paradigm shift in software technology.....	
2. Infection mechanisms, architecture and digital forensic detection.....	
2.1 Social engineering, spear-phishing and zero-click attacks.....	
2.2 Architecture and technical analysis of modern threats.....	
The Pegasus ecosystem (NSO Group).....	
The Predator ecosystem (Cytrox/Intellexa).....	
2.3 Persistence techniques and detection avoidance (anti-forensics/memory-only)....	
2.4 Digital forensic analysis and detection tools (logs, packet capture, MVT).....	
2.5 The need to transition from repressive defence to organic privacy design.....	
3. ISO/IEC 29100 framework and privacy requirements engineering.....	
3.1 Paradigm shift in software technology.....	
3.2 Conceptual foundation and definition of personal data (PII).....	
3.3 Actors and roles in the software lifecycle.....	
3.4 The privacy principles (privacy principles) of ISO 29100 as a barrier to data leakage.....	
3.5 Requirements engineering and architectural design: Embedding privacy from the design (Privacy by Design) and Privacy Enhancing Technologies (PETs).....	
4. The gap between the legal framework and technological reality.....	
4.1 The limits of European Law (GDPR) against State-Sponsored Spyware.....	
4.1.1 Legal gaps and grey zones in the deployment of spyware.....	

4.2 The need for technological (and not only legal) fortification of software.....	
5. Case Study 1 — Analysis of vulnerabilities and redesign of messaging platforms (iMessage/FORCEDENTRY).....	
5.1 Scenario description and anatomy of the FORCEDENTRY attack.....	
5.1.1 Historical background and the evolution of NSO Group's zero-click attacks	
5.1.2 The discovery and context of the FORCEDENTRY attack.....	
5.1.3 Technical analysis and anatomy of CVE-2021-30860.....	
5.2 Analysis of the failure of traditional security mechanisms.....	
5.3 Structural security upgrades in iOS 15 and their correlation with ISO/IEC 29100 and PETs.....	
6. Case Study 2 — Development of an Electronic Health Record (EHR).....	
6.1 Design of a health information system against advanced threats (zero-click spyware).....	
6.2 Role modelling, access rights (RBAC) and purpose limitation based on ISO 29100.....	
6.3 Integration of Privacy Enhancing Technologies (PETs) and data de-identification	
7. Conclusions.....	
7.1 Challenges in the practical application of privacy standards against commercial spyware.....	
7.2 Summary and future directions in software technology.....	
8. Bibliography.....	
9. Term translation tables.....	
9.1 Term Translation Table (English to Greek).....	
9.2 Term Translation Table (Greek to English).....	

1. Introduction to digital espionage and threat evolution

1.1 Definition of spyware and distinction from other malware

Spyware constitutes a special category of malicious software, designed with the primary purpose of covertly collecting, transmitting, and processing data from a target device, without the knowledge or consent of its user.

The peculiarity of spyware lies in the type, sensitivity, and depth of the data it can access: from call records and real-time geolocation to private communications content, photographs, documents, and health data.

The distinction of spyware from related technologies, such as adware or keyloggers, is particularly important both technically and legally.

1.2 Από τα adware στο state-sponsored spyware

The historical evolution of spyware reveals a clear and gradual transition from simple forms of unwanted commercial surveillance to sophisticated state-sponsored digital attack tools.

This transition is directly linked to the transformation of smartphones into the main node of personal, professional, and social life.

Within this technological and political environment, the so-called mercenary or state-sponsored spyware emerged — commercial surveillance software designed to be used by state actors against specific individuals.

1.3 Targets, motivations and the 'Digital Panopticon'

The use of spyware is often justified by state authorities with reference to the need to prevent or suppress terrorism, organised crime, or foreign intelligence activities.

Spyware, therefore, does not function only as a technology of technical access to data, but also as a mechanism producing a deterrence effect — the 'chilling effect'.

The theoretical understanding of the phenomenon can be connected to the concept of the digital Panopticon — a regime where the very possibility of being watched at any moment, without knowing exactly when, shapes behaviour and leads to self-censorship.

1.4 The necessity for a paradigm shift in software technology

The experience of using advanced spyware tools highlights with particular intensity the limits of the traditional security logic.

ISO/IEC 29100:2024 provides a critical theoretical and regulatory framework for this shift. The standard defines a series of privacy principles that must be embedded in the engineering processes of information systems.

Under this lens, the substantive response to spyware cannot be exhausted in repression or detection after infection.

2. 2. Infection mechanisms, architecture and digital forensic detection

2.1 2.1 Social engineering, spear-phishing and zero-click attacks

The infection mechanisms of spyware operate across a wide spectrum, from relatively simple user deception techniques to extremely sophisticated zero-day exploits.

At an even more advanced level, zero-click attacks represent the most concerning form of modern digital surveillance.

2.2 2.2 Architecture and technical analysis of modern threats

2.2.1 The Pegasus ecosystem (NSO Group)

Pegasus is the most well-known and emblematic example of advanced commercial spyware, associated with complex state-sponsored digital surveillance operations.

The Pegasus case has particular importance at the institutional level, as it demonstrates that digital surveillance has evolved into a global industry.

2.2.2 The Predator ecosystem (Cytrox/Intellexa)

Predator constitutes another extremely significant case of mercenary spyware, as it revealed that the international spyware ecosystem is not limited to a single dominant actor but constitutes a complex, multi-node network of companies.

The significance of the Predator case is not only technical but also economic and political. The existence of corporate schemes that develop, sell, and operate these tools through legal structures in multiple jurisdictions creates a complex challenge for regulators.

2.3 2.3 Persistence techniques and detection avoidance (anti-forensics/memory-only)

The effectiveness of modern spyware does not depend exclusively on the initial success of the breach, but also on its ability to remain hidden for long periods.

The difficulty of detection has particular significance at the evidentiary level.

2.4 Digital forensic analysis and detection tools (logs, packet capture, MVT)

Digital forensic analysis in mobile device spyware cases constitutes one of the most demanding fields of modern cybersecurity.

The significance of digital forensic analysis is not only technical but also institutional.

2.5 The need to transition from repressive defence to organic privacy design

The characteristics of modern spyware threats demonstrate that a defensive strategy cannot be based exclusively on detection and response after an infection.

ISO/IEC 29100:2024 supports precisely this logic, as it describes a privacy framework applicable to organisations of all sizes and sectors.

3. 3. ISO/IEC 29100 framework and privacy requirements engineering

3.1 Paradigm shift in software technology

The traditional approach to information security has historically focused on the perimeter protection of systems.

In the traditional security model, the primary concern was the protection of 'information assets'.

In this new paradigm, classical security controls evolve into specialised 'privacy controls'.

3.2 Conceptual foundation and definition of personal data (PII)

The foundation of privacy protection in software technology presupposes the precise determination of the subject of protection.

For the software engineer, understanding the breadth of this definition is decisive, as indirect identification encompasses data that appear anonymous but can be used for re-identification.

This conceptual expansion acquires critical importance when dealing with advanced spyware, since these tools can collect and combine vast amounts of data.

3.3 Actors and roles in the software lifecycle

During the design and development of information systems with privacy in mind, it is necessary to precisely identify who processes data and under what mandate.

On the other hand, the technical implementation of this processing is often assigned to the PII Processor (PII Processor) — the entity that processes data on behalf of the PII Controller.

The strict isolation of these roles in the code and in access rights (access control) is of fundamental importance.

3.4 The privacy principles (privacy principles) of ISO 29100 as a barrier to data leakage

The practical fortification of an information system against the data leakage caused by advanced spyware requires the systematic implementation of the principles of the ISO 29100 standard.

A decisive role in the technical containment of spyware is played by the principles of collection limitation, use limitation, and data minimisation.

Protection is completed at the code level through the principles of individual participation and access of the data subject.

3.5 Requirements engineering and architectural design: Embedding privacy from the design (Privacy by Design) and Privacy Enhancing Technologies (PETs)

Effective protection of an information system against advanced threats, such as spyware, cannot be achieved through ex-post correction of vulnerabilities after they are discovered.

In the context of requirements engineering, this methodology requires designing the system with the assumption of zero trust.

The embedding of privacy in the design functions as an organic barrier against spyware.

4. 4. The gap between the legal framework and technological reality

4.1 4.1 The limits of European Law (GDPR) against State-Sponsored Spyware

The rapid evolution and deployment of advanced commercial spyware technologies have highlighted an apparent inadequacy of existing legal frameworks.

As documented in the academic literature, software such as Pegasus violates both national and international laws.

The GDPR regulates primarily commercial entities and organisations, but explicitly excludes from its scope of application the processing of data for national security purposes.

Furthermore, the GDPR mechanisms are based on the principle of transparency and accountability of controllers — a prerequisite that is structurally impossible to fulfil in cases of covert surveillance.

4.1.1 4.1.1 Legal gaps and grey zones in the deployment of spyware

The gap between legislation and technological reality is further widened by the generalised uncertainty regarding the applicable legal framework.

Within this regime of international legislative vacuum, companies developing these software, such as NSO Group and Intellexa, have exploited grey zones in export control law.

Spyware developers have the capacity to relocate their corporate headquarters or use complex networks of subsidiaries to avoid regulation.

4.2 The need for technological (and not only legal) fortification of software

The failure of legal frameworks to contain the spread and use of spyware demonstrates that purely punitive or regulatory measures are insufficient.

This approach is fully aligned with the philosophy of the ISO/IEC 29100 standard, which introduces the concept of privacy by design as an organic engineering principle.

The integration of Privacy Enhancing Technologies (PETs) at the source code level constitutes the practical means for achieving this objective.

In conclusion, the technological fortification of software does not come to replace the law, but to offer it the technical tools necessary to make legal protection real and effective.

5. Case Study 1 — Analysis of vulnerabilities and redesign of messaging platforms (iMessage/FORCEDENTRY)

5.1 Scenario description and anatomy of the FORCEDENTRY attack

5.1.1 Historical background and the evolution of NSO Group's zero-click attacks

The emergence of zero-click exploit attacks represents the most significant qualitative change in the architecture of modern digital surveillance.

One of the first mass recordings of this transition was noted in 2019 on the WhatsApp platform.

Subsequently, in 2020, the research laboratory 'The Citizen Lab' of the University of Toronto discovered a new zero-click attack leveraging a vulnerability in iMessage.

5.1.2 The discovery and context of the FORCEDENTRY attack

The most advanced and technically sophisticated zero-click attack was recorded in 2021 under the name FORCEDENTRY. Its discovery was made by the Citizen Lab and later analysed in detail by Apple's security team.

These elements included the characteristic structure and format of the malicious files sent, as well as a partial but significant analysis of the exploit code.

This breach had been active at least since February 2021. On 7 September 2021, the Citizen Lab provided Apple's security team with the necessary evidence.

5.1.3 Technical analysis and anatomy of CVE-2021-30860

The vulnerability received the official identifier CVE-2021-30860 from NIST and was classified as an integer overflow vulnerability in CoreGraphics, a fundamental library of the iOS/macOS operating system.

The attackers exploited this automated workflow by applying a series of extremely sophisticated techniques.

In an impressive example of reverse engineering, the Pegasus designers used the basic logical instructions of the JBIG2 format to construct a virtual 64-bit CPU with arbitrary code execution capability.

5.2 Analysis of the failure of traditional security mechanisms

The success of FORCEDENTRY demonstrated that classical defence mechanisms present structural gaps when confronted with advanced zero-click threats.

The FORCEDENTRY attack managed to bypass BlastDoor because the vulnerability resided in the code of a core library (CoreGraphics), outside BlastDoor's protection sphere.

In parallel, the attack neutralised the code signing (Code Signing) mechanism.

With the same methodology, the ASLR mechanism was also neutralised — which randomises the memory locations where OS libraries are loaded.

5.3 Structural security upgrades in iOS 15 and their correlation with ISO/IEC 29100 and PETs

Addressing critical zero-click threats, such as the FORCEDENTRY attack, forced the software industry to shift from reactive patch management to proactive architectural security.

The specific technical interventions of Apple are not simply isolated security measures, but are inextricably linked to the principles of Privacy by Design.

In parallel, these changes integrate the basic philosophy of Privacy Enhancing Technologies (PETs), focusing on the principle of minimal exposure.

Consequently, Apple's architectural shift in iOS 15 demonstrates that effective defence against commercial spyware requires a fundamental change in the engineering approach to software design.

6. Case Study 2 — Development of an Electronic Health Record (EHR)

6.1 Design of a health information system against advanced threats (zero-click spyware)

The development and management of an Electronic Health Record (EHR) constitutes one of the most demanding applications in cybersecurity and privacy protection.

A realistic scenario concerns the use of zero-click spyware (such as Pegasus or Predator) against key persons within a hospital organisation.

For the holistic addressing of this asymmetric threat, the architectural design of the health system cannot be limited to compliance with existing legal frameworks.

According to the international standard ISO/IEC 27701, such a system functions as a natural extension of traditional information security management systems (ISMS according to ISO/IEC 27001) with the addition of privacy management controls.

6.2 Role modelling, access rights (RBAC) and purpose limitation based on ISO 29100

The cornerstone for preventing mass data interception from an infected terminal is the strict application of Role-Based Access Control (RBAC), combined with the Purpose Limitation principle of ISO 29100.

For effective defence against advanced surveillance threats, whether zero-interaction (Pegasus) or via social engineering (Predator), strict Role-Based Access Control must be combined with least privilege principle.

If a spyware infects a user's device, the attacker is confined within the strict limits of that specific role.

6.3 Integration of Privacy Enhancing Technologies (PETs) and data de-identification

Even with strict application of access control (RBAC), an advanced cyberattack with spyware may manage to extract a subset of data from the compromised device.

The ISO/IEC 27701 framework requires organisations to define clear data minimisation objectives and to document them in their Privacy Information Management System (PIMS).

In the event that a spyware manages to extract the table with clinical data, these become practically unusable if they have previously been tokenised or pseudonymised.

7. Conclusions

7.1 Challenges in the practical application of privacy standards against commercial spyware

The practical embedding of international privacy standards (ISO/IEC 29100 and ISO/IEC 27701) in the software development lifecycle faces significant challenges.

The analysis of infection mechanisms revealed that zero-click attacks and advanced anti-forensics techniques (such as memory-only operation) systematically undermine the assumptions on which the traditional reactive security model is based.

7.2 Summary and future directions in software technology

In summary, this research demonstrated that simple legal compliance (e.g. GDPR) or passive release of corrective patches is insufficient to effectively address the threat of advanced commercial spyware.

As regards future directions, software technology must embed privacy assurance requirements as a first-class engineering constraint.

- The systematic use of programming languages with inherent memory safety (memory-safe languages). The gradual replacement of C/C++ with memory-safe languages eliminates entire categories of vulnerabilities.
- The utilisation of Trusted Execution Environments (TEEs). The migration of critical processes (key storage, biometric authentication) to TEEs creates hardware-level isolation zones.

- The integration of advanced cryptographic PETs and microservices architecture (microservices). The complete architectural decoupling of the system into independent microservices minimises lateral movement.
- The addressing of the 'AI Paradox' and the challenges of 'Vibe Coding'. The integration of AI into software development creates new challenges.

In conclusion, facing the asymmetric threat of spyware, software must not merely function correctly — it must be designed to resist even when the developer's assumptions prove wrong.

8. Bibliography

Pegasus-Product Description (NSO)

- [12]: «We provides, as default, one year of maintenance, support and upgrades services. These services include: Maintenance and Support: We provides maintenance services and three-tier level support that includes: ■Tier-1: Standard system operations problems ■Tier-2: Proactive resolving of technical problems Remote assistance using remote desktop software and a Virtual Private Network (VPN) where requested. ■Tier-3: Bug fixing and system updates of substantial system malfunctions. Upgrades: We have releases major upgrades to the Pegasus system few times a year. Such upgrades usually include: New features, New devices/operating system support, Bugs fix.», σελ. 40.

Κατασκοπευτικό Λογισμικό-Spyware (Νικόλαος Α. Τσιρώνης)

- [5]: «Το κρισιμότερο εύρημα της συγκεκριμένης περιόδου, όντας ταυτόχρονα και η γέφυρα παρόντος και μέλλοντος, υπήρξε η ανακάλυψη του δικτύου Ghostnet. Πρόκειται για μια από τις πρώτες επιχειρήσεις κυβερνοκατασκοπείας ευρείας κλίμακας, η οποία δρούσε απαρατήρητη σε 103 χώρες και στοχοποιούσε πρόσωπα υψηλής πολιτικής σημασίας...σηματοδοτώντας την μετάβαση από το οικονομικό έγκλημα στην ψηφιακή επιτήρηση», σελ. 18.
- [60]: «Το AI Paradox αναφέρεται στο φαινόμενο πως τα εργαλεία που χρησιμοποιούνται για την καταπολέμηση των επιθέσεων και την ανίχνευση μοτίβων, αποτελούν ταυτόχρονα τον ισχυρότερο σύμμαχο των επιτιθέμενων... η χρήση του Polymorphic Spyware από τους επιτιθέμενους δυσχεραίνει τον εντοπισμό του κακόβουλου κώδικα...Η τάση ανάπτυξης λογισμικού μέσω prompts παρουσιάζει δύο κύριες απειλές. Αρχικά, το φράγμα εισόδου για την δημιουργία κακόβουλων λογισμικών καταρρίπτεται...Επιπλέον, η παραδοσιακή ανίχνευση βάσει υπογραφών αποδυναμώνεται», σελ. 39-40.

Spyware Technologies: Technical Analysis, Detection and Countermeasures (Pappas Nikolaos)

- [3]: «More complex types, like Pegasus or Predator, are sophisticated tools sometimes called state grade spyware-these programs get around encrypted messaging applications; they also use zero day flaws.», σελ 15.
- [4]: «A device does not show any signs when these programs operate...The program accesses the microphone, camera, or screen. It also tracks the person's location.», σελ 15.
- [9]: «Avanced spyware software also use exploit chains - these chains consist of a series of software flaws linked together to obtain total access to a device. They often target mobile operating systems like iOS or Android, so attackers can get around common security measures such as sandboxing or code signing.», σελ 18.
- [10]: «Zero-click attacks are hard to find and stop mainly because they leave little to no evidence. Forensic checks often uses indirect signs. These signs include odd system actions, strange data transfer and system anomalies.», σελ 19.

- [14]: «Encryption and Obfuscation: Spyware encrypts its communication plus hides its operations...Self-destruct mechanisms: Some spyware deletes itself or its logs if specific events occur, for example, if the SIM card changes or someone finds it... If Pegasus detects threat analysis tools or signs of forensic inspection, it can automatically: Erase itself, Delete related logs, Overwrite memory with null bytes [2]», σελ 26 και 30.
- [15]: «Sophisticated spyware, such as Pegasus and Predator are designed to operate invisibly. On that account, common antivirus software often does not find it. Finding this software requires forensic methods and special tools...Amnesty International developed Mobile Verification Toolkit (MVT). It is an open-source software that helps identify devices that are infected with Pegasus spyware. It works by: Analyzing encrypted iPhone backups, Search for known forensic traces such as suspicious domain/IP contact», σελ 25.
- [16]: «Forensic analysts examine: System logs...Network logs...Application behavior, such as unexpected battery drain or camera activation. Packet Capture and Traffic Analysis: Applications like Wireshark or tcpdump are used to monitor device traffic.», σελ 25-26.
- [47]: «In addition, the Dual-Use Regulation manages the export of sensitive tools, such as spyware, by requiring licenses...Outside the EU, the United States put NSO Group and other spyware sellers on its Entity List.», σελ. 54.
- [51]: «These segments implemented virtual logic gates to simulate a 16-bit arithmetic logic unit (ALU). To put it simply, it created a Virtual Machine inside the image parser», σελ. 28.

Click, Load, Kill: A Look into the Cyberweapon Industry in the WANA Region (SMEX)

- [18]: «When did you first notice things were wrong? What did you notice? What did you do at that point? ...Did you take any precautions online before this attack?», σελ. 108.

Πλαίσιο Ιδιωτικότητας (Privacy framework) ISO 29100:2011/2024 (Στέφανος Γκρίτζαλης)

- [7]: «Πλαίσιο Ιδιωτικότητας (Privacy framework) ISO 29100:2011/2024», σελ. 1.
- [22]: «PII» (αριστερή στήλη) και «Information Asset» (δεξιά στήλη), σελ. 126.
- [24]: «Privacy control» (αριστερή στήλη) και «Control» (δεξιά στήλη), σελ. 126.
- [25]: «Privacy breach» (αριστερή στήλη) και «Information Security incident» (δεξιά στήλη). Επίσης, πιο κάτω αναγράφει «Privacy risk» (αριστερή στήλη) και «Risk» (δεξιά στήλη), σελ. 126.
- [26]: «Privacy safeguarding requirements» (αριστερή στήλη) και «Control objectives» (δεξιά στήλη), σελ. 126.
- [27]: «Privacy risk management» (αριστερή στήλη) και «Risk management» (δεξιά στήλη), σελ. 126.
- [28]: «Αναγνωριστικά στοιχεία ταυτότητας (PII personally identifiable information)», σελ. 11.
- [30]: «Υποκείμενο των δεδομένων (PII principal)», «Φυσικό πρόσωπο με το οποίο σχετίζονται αναγνωριστικά στοιχεία», σελ. 12.
- [33]: «Δικαιούχος Ιδιωτικότητας (privacy stakeholder)», «Φυσικό ή νομικό πρόσωπο, δημόσια αρχή, οργανισμός ή άλλος φορέας που μπορεί να επηρεάσει, να επηρεαστεί ή θεωρεί ότι επηρεάζεται από απόφαση ή δραστηριότητα που σχετίζεται με αναγνωριστός ταυτότητας PII», σελ. 11.
- [34]: «Υπεύθυνος επεξεργασίας αναγνωριστικών στοιχείων ταυτότητας (PII controller)» «Δικαιούχος ιδιωτικότητας (privacy stakeholder) που προσδιορίζει τον σκοπό και τα μέσα για την επεξεργασία αναγνωριστικών στοιχείων ταυτότητας PII, διαφορετικός από φυσικά πρόσωπα που χρησιμοποιούν δεδομένα για προσωπικό σκοπό», σελ. 12.
- [37]: «5. Οι αρχές (principles) ιδιωτικότητας», σελ. 90.

ISO/IEC 29100 (2024)

- [23]: «natural person to whom the personally identifiable information (PII) (3.7) relates», σελ. 2.
- [29]: «information that (a) can be used to establish a link between the information and the natural person to whom such information relates, or (b) is or might be directly or indirectly linked to a natural person», σελ. 2.
- [31]: «To determine whether a PII principal is identifiable, account should be taken of all the means which can reasonably be used by the privacy stakeholder holding the data, or by any other party, to establish the link between the set of PII and the natural person.», σελ. 2.
- [32]: «The increasing commercial use and value of PII, the sharing of PII across jurisdictions, and the growing complexity of ICT systems, can make it difficult for an organization to ensure privacy and to achieve compliance with the various applicable laws.», σελ. v.
- [21]: «This document provides a high-level framework for the protection of personally identifiable information (PII) within information and communication technology (ICT) systems. It is general in nature and places organizational, technical, and procedural aspects in an overall privacy framework.», σελ. v.
- [35]: «privacy stakeholder that processes personally identifiable information (PII) (3.7) on behalf of and in accordance with the instructions of a PII controller (3.8)», σελ. 2.
- [36]: «privacy stakeholder (3.20) other than the personally identifiable information (PII) principal (3.9), the PII controller (3.8) and the PII processor (3.10), and the natural persons who are authorized to process the data under the direct authority of the PII controller or the PII processor», σελ. 4.
- [38]: «6.2 Consent and choice» «6.3 Purpose legitimacy and specification» «Adhering to the purpose legitimacy and specification principle involves: ensuring

that the purpose(s) complies with applicable law and relies on a permissible legal basis;», σελ. 14-15.

- [39]: «6.4 Collection limitation: limiting the collection of PII to that which is within the bounds of applicable law and strictly necessary for the specified purpose(s). [...] 6.5 Data minimization: minimize the PII which is processed and the number of privacy stakeholders and people to whom PII is disclosed or who are allowed to process it;», σελ. 15.
- [40]: «6.6 Use, retention and disclosure limitation», «6.7 Accuracy and quality», «6.8 Openness, transparency and notice», σελ. 16.
- [41]: «6.9 Individual participation and access», «6.10 Accountability», «6.11 Information security», «6.12 Privacy compliance», σελ. 17-19.
- [42]: «6.5 Data minimization» «minimize the PII which is processed and the number of privacy stakeholders and people to whom PII is disclosed or who are allowed to process it;», σελ. 15.
- [43]: «The privacy framework is intended to help organizations define their privacy safeguarding requirements related to PII within an ICT environment», «Use of this document will: aid in the design, implementation, operation, and maintenance of ICT systems that handle and protect PII;», σελ. v.

ISO/IEC 27701 (2025)

- [52]: «This document specifies requirements for establishing, implementing, maintaining and continually improving a privacy information management system (PIMS).», σελ. 1.
- [53]: «This document enables an organization to align or integrate its privacy information management system (PIMS) with the requirements of other management system standards, and in particular with the information security management system specified in ISO/IEC 27001.», σελ. vi.

- [57]: «The organization should define and document data minimization objectives and what mechanisms (such as de-identification) are used to meet those objectives.», σελ. 30.
- [58]: «In these cases, the organization should define and document the extent to which the PII should be associated with the PII principal, as well as the mechanisms and techniques designed to process PII, such that the de-identification and PII minimization objectives are achieved.», σελ. 30.
- [59]: «The organization should either delete PII or render it in a form which does not permit identification or re-identification of PII principals, as soon as the original PII is no longer necessary for the identified purpose(s).», σελ. 31.

Supplementary Material

- [1] European Parliament (2023) The impact of Pegasus on fundamental rights and democratic processes. Brussels: European Parliament. Available at: [https://www.europarl.europa.eu/RegData/etudes/STUD/2022/740514/IPOL_STU\(2022\)740514_EN.pdf](https://www.europarl.europa.eu/RegData/etudes/STUD/2022/740514/IPOL_STU(2022)740514_EN.pdf)
- [2] European Parliament Research Service (2023) Investigation of the use of Pegasus and equivalent surveillance spyware. Brussels: European Parliament. Available at: [https://www.europarl.europa.eu/RegData/etudes/ATAG/2023/747923/EPRS_ATAG\(2023\)747923_EN.pdf](https://www.europarl.europa.eu/RegData/etudes/ATAG/2023/747923/EPRS_ATAG(2023)747923_EN.pdf)
- [6] European Parliament Think Tank (2024) What action has Parliament taken against spyware abuse? Available at: [What action has Parliament taken against spyware abuse? | Epthinktank](#)
- [19] European Data Protection Board (2020) Guidelines 4/2019 on Article 25 Data Protection by Design and by Default. Available at: [Guidelines 4/2019 on Article 25 Data Protection by Design and by Default](#)

- [20] European Commission (n.d.) What does data protection by design and by default mean? Available at: [What does data protection ‘by design’ and ‘by default’ mean? - European Commission](#)
- [8] ENISA (2024) ENISA Threat Landscape 2024. Available at: [ENISA Threat Landscape 2024](#)
- [11] Citizen Lab. Hide and Seek: Tracking NSO Group's Pegasus Spyware to Operations in 45 Countries. Available at: [HIDE AND SEEK: Tracking NSO Group’s Pegasus Spyware to Operations in 45 Countries - The Citizen Lab](#)
- [13] Kaspersky. What commercial spyware is, and what different types there are. Kaspersky official blog. Available at: [What commercial spyware is, and what different types there are | Kaspersky official blog](#)
- [17] Cyber Forensic Academy. Best Network Forensic Tools for Packet & Log Analysis. Available at: [https://www-cyberforensicacademy-com.translate.goog/blog/best-network-forensic-tools-for-packet-log-analysis? x tr sl=en& x tr tl=el& x tr hl=el& x tr_pto=sge](#)
- [44]: Kareem, K.M., 2024. A comprehensive analysis of pegasus spyware and its implications for digital privacy and security. arXiv preprint arXiv:2404.19677.
- [45]: Anstis, S., 2024. Regulating transnational dissident cyber espionage. International & Comparative Law Quarterly, 73(1), pp.259-274.
- [46]: Marczak, B., Scott-Railton, J., Al-Jizawi, S., Anstis, S. και Deibert, R., 2020. The Great iPwn: Journalists Hacked with Suspected NSO Group iMessage Zero-Click Exploit. The Citizen Lab. Available at: [https://citizenlab.ca/research/the-great-ipwn-journalists-hacked-with-suspected-nso-group-imessage-zero-click-exploit/](#)
- [48]: Marczak, B., Scott-Railton, J., McKune, S., Razzak, B. και Deibert, R., 2021. FORCEDENTRY: NSO Group iMessage Zero-Click Exploit Captured in the Wild.

The Citizen Lab. Available at: <https://citizenlab.ca/research/forcedentry-nso-group-imessage-zero-click-exploit-captured-in-the-wild/>

- [49]: Apple, 2021. Apple sues NSO Group to curb the abuse of state-sponsored spyware. Apple Newsroom. Available at: <https://www.apple.com/sa/newsroom/2021/11/apple-sues-nso-group-to-curb-the-abuse-of-state-sponsored-spyware/>
- [50]: National Vulnerability Database (NVD), 2021. CVE-2021-30860 Detail. NIST. Available at: <https://nvd.nist.gov/vuln/detail/CVE-2021-30860>
- Personal Data (Privacy) Ordinance and Electronic Health System: Points to Note for Healthcare Providers and Healthcare Professionals [54-56]:
 - o [54]: «The Electronic Health System Ordinance, Cap. 625 ("eHealth Ordinance") provides a legal basis for the collection, sharing, use, and safekeeping of patients' health data under the Electronic Health System ("eHealth System").», σελ. 2.
 - o [55]: «The eHealth System is an information infrastructure for healthcare providers (including doctors and other healthcare professionals) in both the public and private sectors to, with the consent of a patient, access and share the patient's health record for healthcare-related purposes.», σελ. 2.
 - o [56]: «Patients' health records in the eHealth System amount to personal data, which is protected under the Personal Data (Privacy) Ordinance, Cap. 486 ("PDPO"). Healthcare providers and the Commissioner for the Electronic Health Record, as data users, should act in accordance with the requirements under the eHealth Ordinance as well as the PDPO (including the Six Data Protection Principles ("DPPs"))», σελ. 2.
- Hong Kong Government, 2026. Electronic Health System Ordinance (Cap. 625). Consolidated version. Retrieved from <https://www.elegislation.gov.hk/hk/cap625!en>

- Admin. (2023, July 21). Enhancing Healthcare Data Security with Managed Services-EHR Role Based Access-Ellit Groups. Retrieved from <https://ellitgroups.com/enhancing-healthcare-data-security-with-managed-services-ehr-role-based-access/>
- Henry, K. (2026, March 16). Role-Based Access Control (RBAC) in healthcare: benefits, examples, and best practices. Retrieved from <https://www.accountablehq.com/post/role-based-access-control-rbac-in-healthcare-benefits-examples-and-best-practices>
- EHealth. (n.d.). Retrieved from <https://www.ehealth.gov.hk/en/whats-ehealth/access-control.html>
- National Vulnerability Database (NVD), 2019. CVE-2019-3568 Detail. NIST. Available at: <https://nvd.nist.gov/vuln/detail/CVE-2019-3568>

9. Term translation tables

9.1 Term Translation Table (English to Greek)

Αγγλικός Όρος (Original Term)	Ελληνική Απόδοση (Greek Term)
Accountability	Λογοδοσία
Accuracy and quality	Ακρίβεια και ποιότητα
Adware	Λογισμικό εμπορικής παρακολούθησης/διαφήμισης

Anti-forensics	Τεχνικές αποφυγής δικανικού εντοπισμού
Arithmetic Logic Unit (ALU)	Αριθμητική και Λογική Μονάδα
Buffer overflow	Υπερχείλιση προσωρινής μνήμης (Buffer)
Bug fixing	Διόρθωση σφαλμάτων
Code signing	Ψηφιακή υπογραφή κώδικα
Collection limitation	Περιορισμός συλλογής
Consent and choice	Συγκατάθεση και επιλογή
Control objectives	Αντικειμενικοί στόχοι ελέγχου
Data minimization	Ελαχιστοποίηση δεδομένων
De-identification	Απο-ταυτοποίηση
Digital forensics/Forensic traces	Ψηφιακή δικανική ανάλυση/Εγκληματολογικά ίχνη
Electronic Health Record (EHR)	Ηλεκτρονικός Φάκελος Υγείας

Exploit chains	Αλυσίδες εκμετάλλευσης ευπαθειών
Heap spraying/Heap corruption	Τεχνική ψεκασμού σωρού μνήμης/Αλλοίωση σωρού μνήμης
Indicators of Compromise (IoC)	Δείκτες παραβίασης
Informed consent	Ενημερωμένη συγκατάθεση
Information Asset	Περιουσιακό στοιχείο πληροφοριών
Information Security	Ασφάλεια πληροφοριών
Integer overflow	Υπερχείλιση ακέραιου αριθμού
Major upgrades	Σημαντικές αναβαθμίσεις
Memory-safe languages	Γλώσσες προγραμματισμού με εγγενή ασφάλεια μνήμης
Mercenary/State-sponsored spyware	Μισθοφορικό/Κρατικά υποστηριζόμενο κατασκοπευτικό λογισμικό
Mobile Verification Toolkit (MVT)	Εργαλειοθήκη επαλήθευσης κινητών συσκευών
Openness, transparency and notice	Ανοικτότητα, διαφάνεια και ενημέρωση

Packet capture	Καταγραφή πακέτων δικτύου
Paradigm shift	Αλλαγή υποδείγματος/Ριζική μεταβολή
Personally Identifiable Information (PII)	Προσωπικά αναγνωρίσιμες πληροφορίες/Αναγνωριστικά στοιχεία ταυτότητας
PII Controller	Υπεύθυνος επεξεργασίας PII
PII Principal	Υποκείμενο των PII (Φυσικό πρόσωπο)
PII Processor	Εκτελών την επεξεργασία PII
Polymorphic Spyware	Πολυμορφικό κατασκοπευτικό λογισμικό
Privacy breach	Παραβίαση ιδιωτικότητας
Privacy compliance	Συμμόρφωση με την ιδιωτικότητα
Privacy control	Έλεγχος ιδιωτικότητας
Privacy Engineering	Μηχανική της ιδιωτικότητας
Privacy Information Management System (PIMS)	Σύστημα διαχείρισης ιδιωτικότητας πληροφοριών

Privacy risk management	Διαχείριση κινδύνου ιδιωτικότητας
Privacy safeguarding requirements	Απαιτήσεις διασφάλισης της ιδιωτικότητας
Privacy stakeholder	Ενδιαφερόμενο μέρος για την ιδιωτικότητα/Δικαιούχος ιδιωτικότητας
Purpose legitimacy and specification	Νομιμότητα και καθορισμός σκοπού
Re-identification	Επανα-ταυτοποίηση
Remote assistance	Απομακρυσμένη βοήθεια
Role-Based Access Control (RBAC)	Έλεγχος πρόσβασης βάσει ρόλων
Sandboxing	Μηχανισμός απομόνωσης εφαρμογών
Social engineering/Spear-phishing	Κοινωνική μηχανική/Στοχευμένη ηλεκτρονική εξαπάτηση
Spyware	Κατασκοπευτικό λογισμικό
Third party	Τρίτο μέρος
Three-tier level support	Τεχνική υποστήριξη τριών επιπέδων

Trusted Execution Environments (TEEs)	Αξιόπιστα Περιβάλλοντα Εκτέλεσης
Use, retention and disclosure limitation	Περιορισμός χρήσης, διακράτησης και κοινοποίησης
Virtual Machine	Εικονική μηχανή
Zero-click attacks/exploits	Επιθέσεις μηδενικού κλικ (χωρίς διάδραση του χρήστη)
Zero-day flaws/vulnerabilities	Άγνωστες ευπάθειες (μηδενικής ημέρας)
Zero Trust Architecture	Αρχιτεκτονική μηδενικής εμπιστοσύνης

9.2 Term Translation Table (Greek to English)

Ελληνικός όρος (Original Term)	Αγγλικός όρος (English Term)
Ακρίβεια και ποιότητα	Accuracy and quality
Αλλαγή υποδείγματος/Πιζική μεταβολή	Paradigm shift
Ανοικτότητα, διαφάνεια και ενημέρωση	Openness, transparency and notice
Αξιολόγηση κινδύνου/Διαχείριση κινδύνου	Privacy risk management

Αξιόπιστα Περιβάλλοντα Εκτέλεσης	Trusted Execution Environments (TEEs)
Απαιτήσεις διασφάλισης της ιδιωτικότητας	Privacy safeguarding requirements
Απο-ταυτοποίηση	De-identification
Απομακρυσμένη βοήθεια	Remote assistance
Αριθμητική και Λογική Μονάδα	Arithmetic Logic Unit (ALU)
Αρχιτεκτονική μηδενικής εμπιστοσύνης	Zero Trust Architecture
Ασφάλεια πληροφοριών	Information Security
Γλώσσες προγραμματισμού με εγγενή ασφάλεια μνήμης	Memory-safe languages
Δείκτες παραβίασης	Indicators of Compromise (IoC)
Διόρθωση σφαλμάτων	Bug fixing
Εικονική μηχανή	Virtual Machine
Εκτελών την επεξεργασία PII	PII Processor

Ελαχιστοποίηση δεδομένων	Data minimization
Ενδιαφερόμενο μέρος για την ιδιωτικότητα	Privacy stakeholder
Ενημερωμένη συγκατάθεση	Informed consent
Έλεγχος ιδιωτικότητας	Privacy control
Έλεγχος πρόσβασης βάσει ρόλων	Role-Based Access Control (RBAC)
Επανα-ταυτοποίηση	Re-identification
Επιθέσεις/Ευπάθειες μηδενικού κλικ	Zero-click attacks/exploits
Εργαλειοθήκη επαλήθευσης κινητών συσκευών	Mobile Verification Toolkit (MVT)
Ηλεκτρονικός Φάκελος Υγείας	Electronic Health Record (EHR)
Καταγραφή πακέτων δικτύου	Packet capture
Κατασκοπευτικό λογισμικό	Spyware
Κοινωνική μηχανική/Στοχευμένη ηλεκτρονική εξαπάτηση	Social engineering/Spear-phishing

Λογισμικό εμπορικής παρακολούθησης/διαφήμισης	Adware
Λογοδοσία	Accountability
Μηχανική της ιδιωτικότητας	Privacy Engineering
Μηχανισμός απομόνωσης εφαρμογών	Sandboxing
Μισθοφορικό/Κρατικό κατασκοπευτικό λογισμικό	Mercenary/State-sponsored spyware
Νομιμότητα και καθορισμός σκοπού	Purpose legitimacy and specification
Παραβίαση ιδιωτικότητας	Privacy breach
Περιουσιακό στοιχείο πληροφοριών	Information Asset
Περιορισμός συλλογής	Collection limitation
Περιορισμός χρήσης, διακράτησης και κοινοποίησης	Use, retention and disclosure limitation
Πολυμορφικό κατασκοπευτικό λογισμικό	Polymorphic Spyware
Προσωπικά αναγνωρίσιμες πληροφορίες	Personally Identifiable Information (PII)

Σημαντικές αναβαθμίσεις	Major upgrades
Στοχευμένες αλυσίδες εκμετάλλευσης ευπαθειών	Exploit chains
Συγκατάθεση και επιλογή	Consent and choice
Συμμόρφωση με την ιδιωτικότητα	Privacy compliance
Σύστημα διαχείρισης ιδιωτικότητας πληροφοριών	Privacy Information Management System (PIMS)
Τεκμήρια/Εγκληματολογικά ίχνη	Forensic traces/evidence
Τεχνικές αποφυγής δικανικού εντοπισμού	Anti-forensics
Τεχνική υποστήριξη τριών επιπέδων	Three-tier level support
Τράπεζα/Σωρός μνήμης (Heap) και αλλοίωση αυτού	Heap spraying/Heap corruption
Τρίτο μέρος	Third party
Υπεύθυνος επεξεργασίας PII	PII Controller
Υπερχείλιση ακέραιου αριθμού/προσωρινής μνήμης	Integer overflow/Buffer overflow

Υποκείμενο των ΡΠΙ (Φυσικό πρόσωπο)	PII Principal
Ψηφιακή δικανική ανάλυση	Digital forensics
Ψηφιακή υπογραφή κώδικα	Code signing